

Penetration Testing Report

Mediroza General Hospital

Batch B083 | Week 4

Target: <https://medirozahospital.com>

Prepared by: Kritika Rai

CLIENT	TYPE	DURATION
Mediroza General Hospital	Black-box Pentest	5 Days

This project was done in a safe, controlled environment for learning purposes, with written permission from the client. Never use these methods on a real system without written permission.

01. Executive Summary

Networkwalks ran a black-box penetration test on Mediroza General Hospital's website (medirozahospital.com). A black-box test means we started with zero inside knowledge — no logins, no staff help, nothing. The goal was simple: try to break in the way a real attacker would, show exactly how far that attacker could get, and explain how to stop them.

Here is the short version of what happened, step by step:

- We found weak spots in the patient login page, including a SQL injection bug.
- That bug let us get into the patient portal without a real account.
- Inside, we found and downloaded 3 real patient lab report PDFs — all locked with a password.
- We cracked all 3 passwords. They were weak (two were '123456' and 'password').
- One PDF's hidden file details (metadata) mentioned an old database backup, still sitting on the server.
- That backup folder had no protection — anyone could browse and download it.
- The backup file contained the full staff list (30 employees, with salaries and ID numbers) and the full shareholder list (10 owners, with ownership percentages).

Overall Risk to Client: CRITICAL

In plain terms: an attacker with no password and no inside help could have taken patient medical data, every employee's salary and ID number, and the hospital's ownership details. This needs to be fixed immediately.

Key Numbers

- 8 problems found in total — 3 Critical, 1 High, 2 Medium, 2 Low
- 3 out of 3 patient PDF reports opened and read
- 30 staff records exposed — names, salaries, phone numbers and ID numbers
- 10 shareholder records exposed — names and ownership percentages

02. Scope and Methodology

Scope — what we were allowed to test

- Only the website <https://medirozahospital.com> and anything directly reachable from it.
- Black-box test — we were given no logins, no internal documents, no help from staff.
- Rules: stay inside the target domain, no tricking staff (no social engineering), no crashing the site (no denial-of-service), no testing outside this scope.
- Mediroza General Hospital gave written permission for this test before it started.

Methodology — how we worked

We followed the project's own 3-step plan:

- M1 — Initial Access: look around the site, find a way in, and get the 3 confidential patient PDF reports.
- M2 — Data Extraction: crack the password on each of those 3 PDF files.
- M3 — Critical Data Exposure: dig deeper into what we found, which led us to staff salaries and shareholder data.

After testing, we wrote up every finding, rated its risk, and gave clear steps to fix each one — that is this report.

Tools We Used

- nslookup, whois, whatweb, curl — basic look-up tools to learn about the website and server
- A normal web browser — to test the login form and browse folders by hand
- A hash calculator and password cracker tool — to recover PDF passwords
- exiftool — to read hidden file details (metadata) inside a PDF

Limits of This Test

This was a black-box test with a tight scope and a 5-day window. It shows what we could find through the public website alone, using the tools above. A deeper test (with staff help, or more time) could well find more issues.

03. Findings and Proof

Below, each problem is grouped under the milestone (M1, M2 or M3) where we found it, in the order we actually found them.

M#	ID	What we found	Risk
M1	F8	robots.txt reveals hidden folders	Low
M1	F7	Login form leaks valid usernames	Low
M1	F1	SQL injection on the login form	Critical
M1	F2	Login can be bypassed to view patient reports	Critical
M2	F5	Patient PDF passwords are weak and crackable	Medium
M3	F6	PDF file details leak the backup's location	Medium
M3	F4	Old backup folder is open for anyone to browse	High
M3	F3	Full database backup file is public — no login needed	Critical

M1 — Initial Access

Goal: break into the website and get the 3 confidential patient PDF reports.

Step 0 — Looking Around (Recon)

Before trying to break anything, we first looked up basic public information about the site.

```
(kali@kali) ~  
$ whois medirozahospital.com  
Domain Name: MEDIROZAHOSPITAL.COM  
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.namecheap.com  
Registrar URL: http://www.namecheap.com  
Updated Date: 2026-08-14T21:07:45Z  
Creation Date: 2026-08-14T20:51:24Z  
Registry Expiry Date: 2027-08-14T20:51:24Z  
Registrar: Namecheap, Inc.  
Registrar IANA ID: 1068  
Registrar Abuse Contact Email: abuse@namecheap.com  
Registrar Abuse Contact Phone: +1.6613102107  
Domain Status: clientTransferProhibited https://icann.org/epp/clientTransferProhibited  
Name Server: DNS1.NAMACHEAPHOSTING.COM  
Name Server: DNS2.NAMACHEAPHOSTING.COM  
DNSSEC: unsigned  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/  
>> Last update of whois database: 2026-10-01T15:18:58Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/epp  
  
NOTICE: The expiration date displayed in this record is the date the  
registrar's sponsorship of the domain name registration in the registry is  
currently set to expire. This date does not necessarily reflect the expiration  
date of the domain name registrant's agreement with the sponsoring  
registrar. Users may consult the sponsoring registrar's Whois database to  
view the registrar's reported date of expiration for this registration.  
  
TERMS OF USE: You are not authorized to access or query our Whois  
database through the use of electronic processes that are high-volume and  
automated except as reasonably necessary to register domain names or  
modify existing registrations; the Data in VeriSign Global Registry  
Services' ("VeriSign") Whois database is provided by VeriSign for
```

Figure M1.R1 — Who owns the domain and where it is hosted.

```
(kali@kali) ~  
$ nslookup medirozahospital.com  
Server:      8.8.8.8  
Address:     8.8.8.8#53  
  
Non-authoritative answer:  
Name:   medirozahospital.com  
Address: 199.188.201.16
```

Figure M1.R2 — The website's server address (IP).

```
(kali@kali) ~  
$ whatweb https://medirozahospital.com  
https://medirozahospital.com [403 Forbidden] Country[UNITED STATES][en], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403  
Forbidden][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]
```

Figure M1.R3 — The web server software in use (LiteSpeed).

```
(kali㉿kali)-[~]
$ curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Thu, 01 Oct 2026 15:32:51 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed
```

Figure M1.R4 — Server details confirmed again from the raw web response.

F8 — robots.txt Reveals Hidden Folders [LOW]

Where	https://medirozahospital.com/robots.txt
What we found	- This file tells search engines which folders NOT to show in search results. - It listed 3 folders: /patient/, /staff/ and /old/. - That is useful to search engines — but it is just as useful to an attacker, because now we know these 3 folders exist.
Why it matters	On its own this is low risk. But it pointed us straight at the /old/ folder, which later turned out to hold the exposed database backup (see F3).

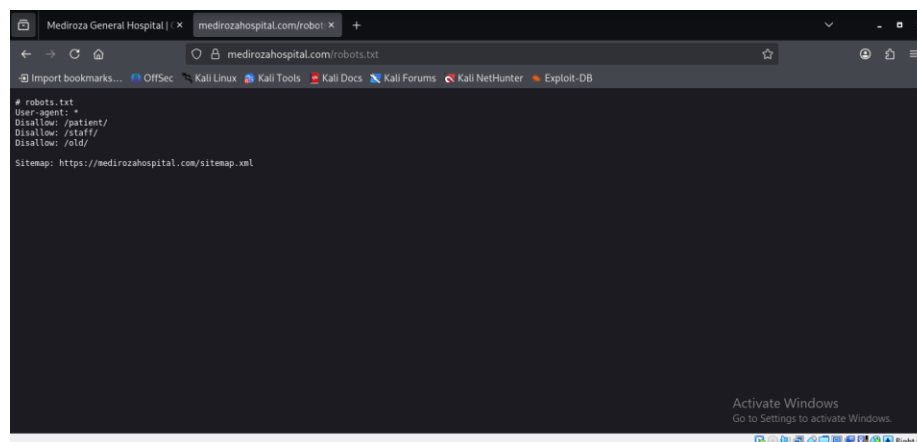


Figure F8.1 — robots.txt listing the /patient/, /staff/ and /old/ folders.

F7 — Login Form Leaks Valid Usernames [LOW]

Where	https://medirozahospital.com/patient/login.php
What we found	- When we typed in a username that does not exist, the site said exactly that: 'Username not found'. - A safer site would just say 'Invalid username or password' every time, without saying which part was wrong.
Why it matters	This lets an attacker quietly check thousands of usernames and build a list of real accounts to attack later.

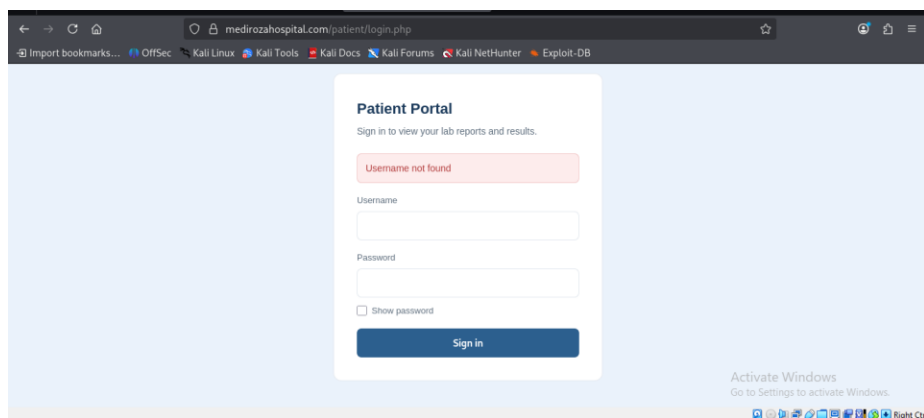


Figure F7.1 — The site confirms a username does not exist.

F1 — SQL Injection on the Login Form [CRITICAL]

Where	https://medirozahospital.com/patient/login.php
What we found	- We typed a single quote mark (') into the Username box, nothing else. - The site crashed and showed us a raw database error message. - This proves the site takes what we type and pastes it straight into a database command, without checking it first. - This bug is called SQL Injection — one of the most common and most dangerous website bugs.
Why it matters	An attacker can use this one bug to skip the login completely, read private data straight from the database, or even change or delete data — all without ever having a real password.

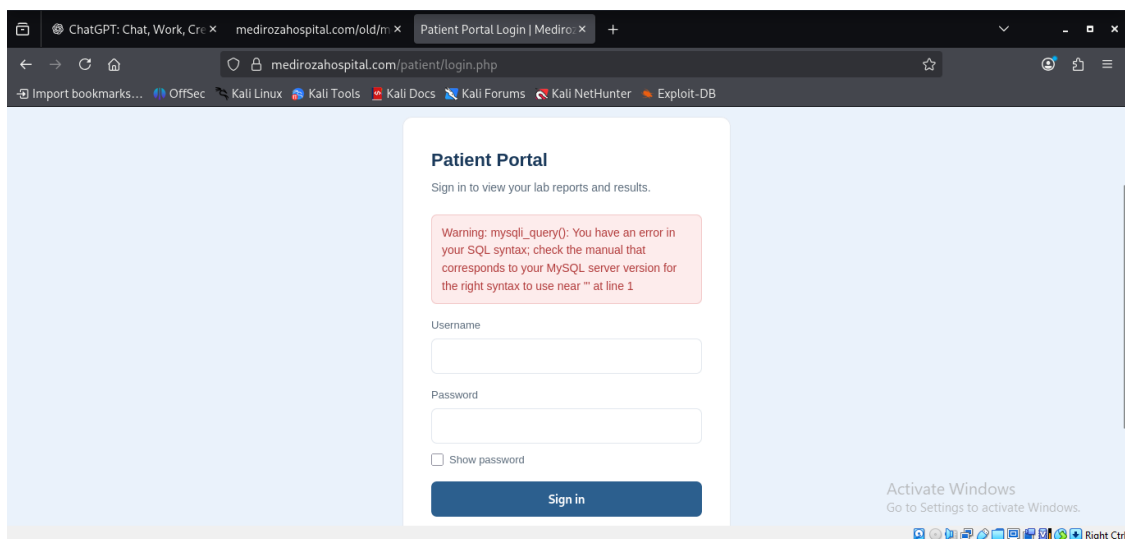


Figure F1.1 — A database error message appears after typing a single quote mark.

F2 — Login Can Be Bypassed to View Patient Reports [CRITICAL]

Where	https://medirozahospital.com/patient/portal.php
What we found	- Using the same weakness as F1, we got into the 'My Lab Reports' page without logging in as a real patient. - That page showed 3 real patients by name: S. Dlamini, P. Reddy and E. Thompson.

	• Next to each name was a direct download link to their private pathology lab report (a PDF file).
Why it matters	• This is a real patient data breach. Anyone could see patient names and download their private medical lab results, without any password.

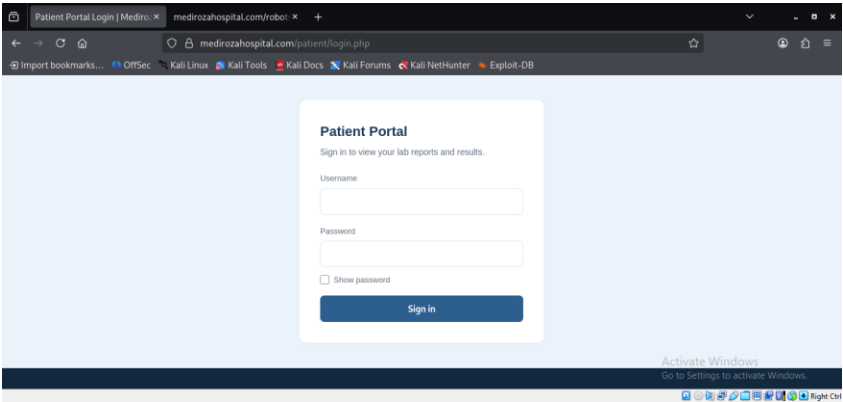


Figure F2.1 — The patient login page.

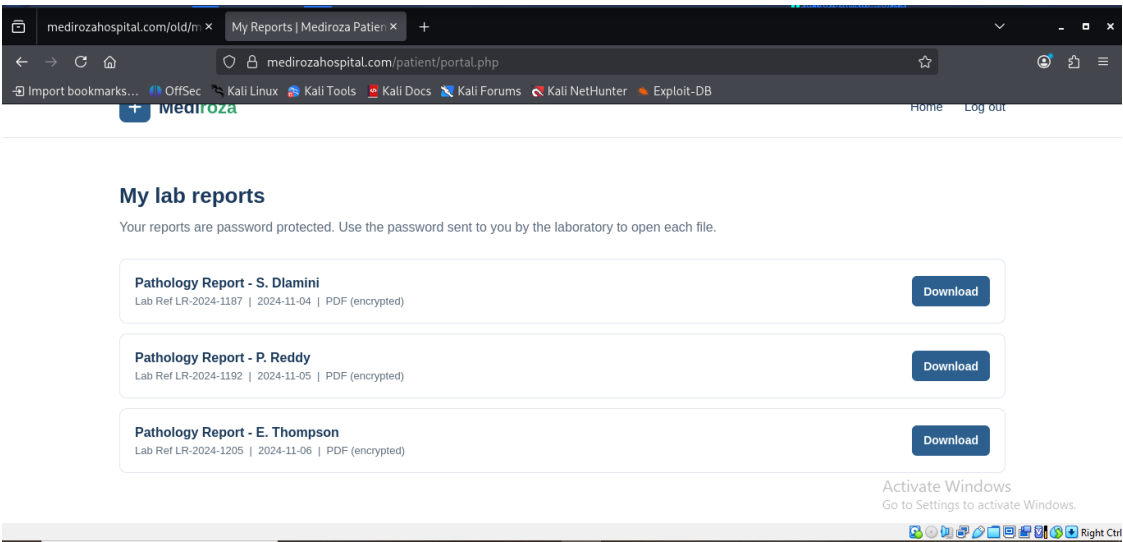


Figure F2.2 — Inside the portal: 3 real patients and their PDF reports, with no real login.

M2 — Data Extraction

Goal: crack the password protecting each of the 3 PDF files.

F5 — Patient PDF Passwords Are Weak and Crackable [MEDIUM]

Where	• The 3 patient PDF files downloaded in M1
What we found	• Each PDF was locked with a password (encrypted). • We pulled a 'crackable hash' out of each file — this is a special code that lets a computer test passwords quickly, without opening the real file. • Report 1 password: '123456' — cracked in seconds using a small, 100-word list. • Report 2 password: 'password' — also cracked in seconds with the same small list. • Report 3 did not crack with that small list, so we tried again with a bigger, 3,556-word list. It cracked to: '!@#\$\$%^&'.

Why it matters

- A password lock is only as strong as the password itself. These passwords were so weak that basic, free tools cracked all 3 files — meaning the 'protection' on this confidential medical data was not real protection at all.

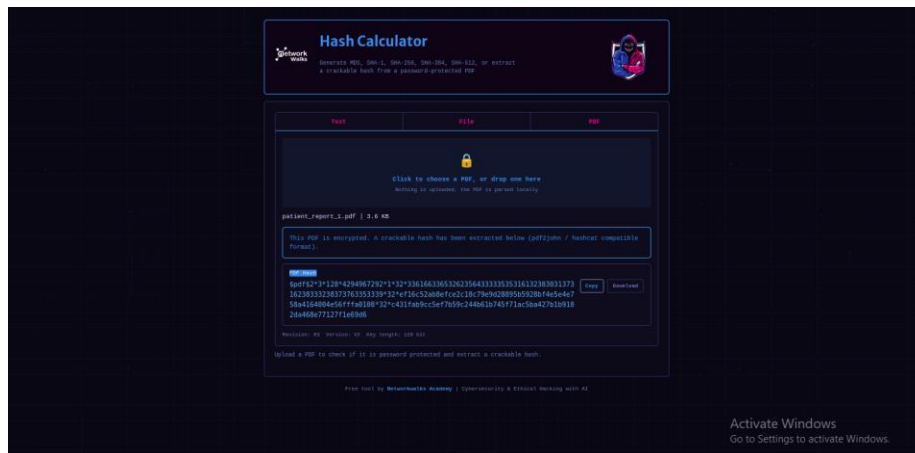


Figure F5.1 — Crackable code pulled from Report 1.

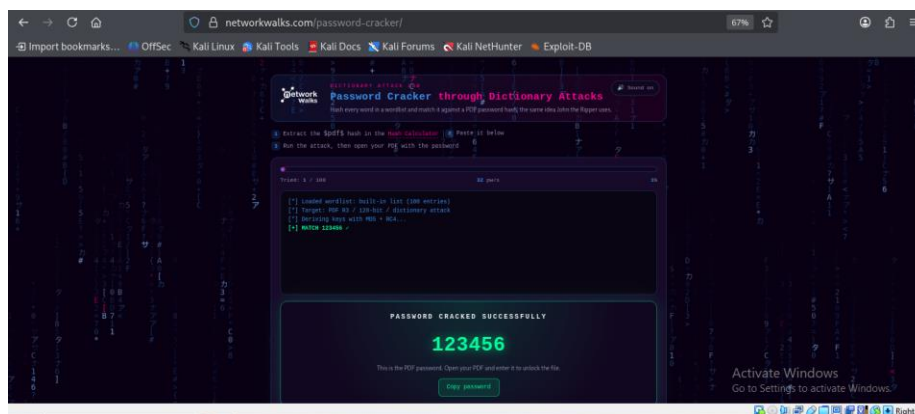


Figure F5.2 — Report 1 password cracked: '123456'.

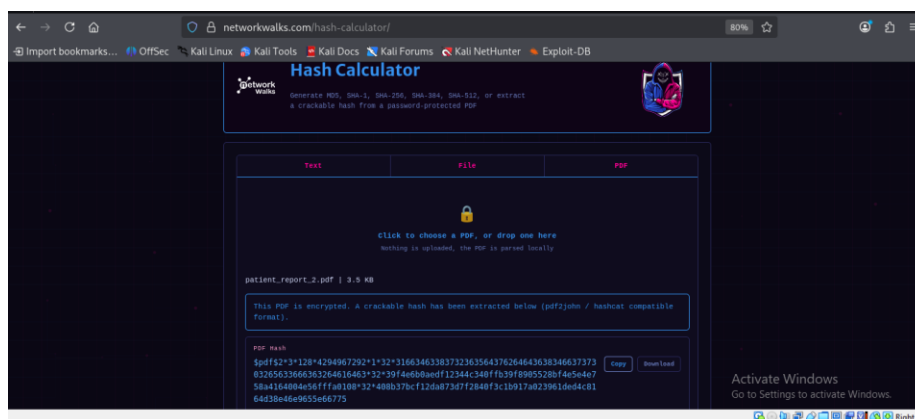


Figure F5.3 — Crackable code pulled from Report 2.

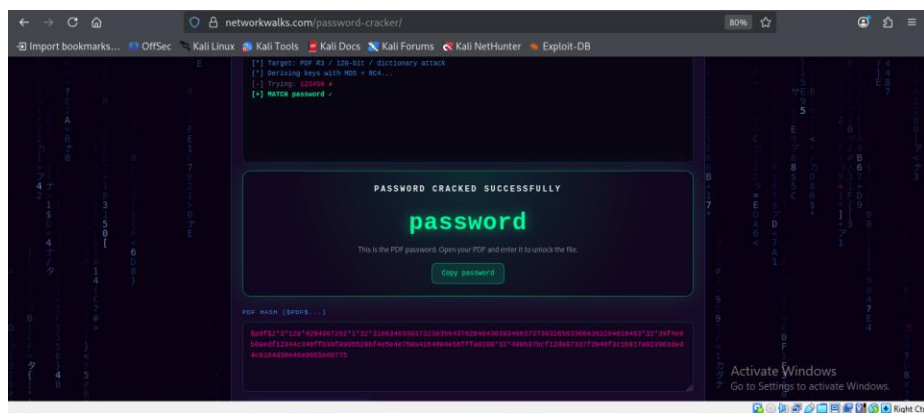


Figure F5.4 — Report 2 password cracked: 'password'.

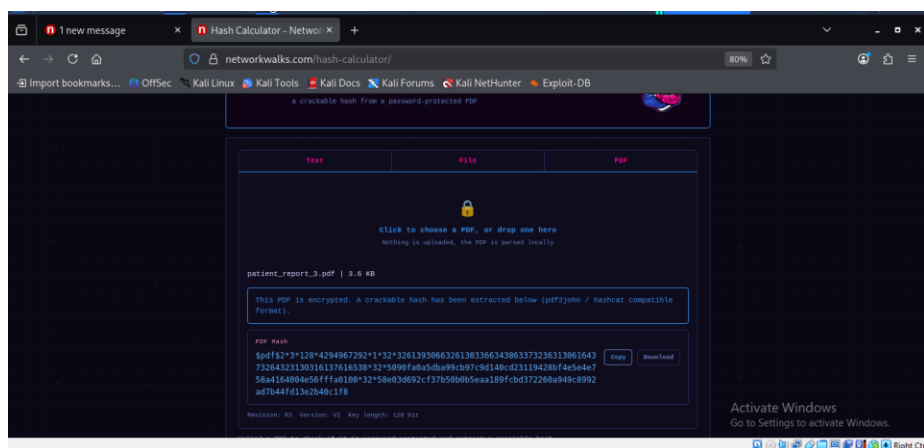


Figure F5.5 — Crackable code pulled from Report 3.

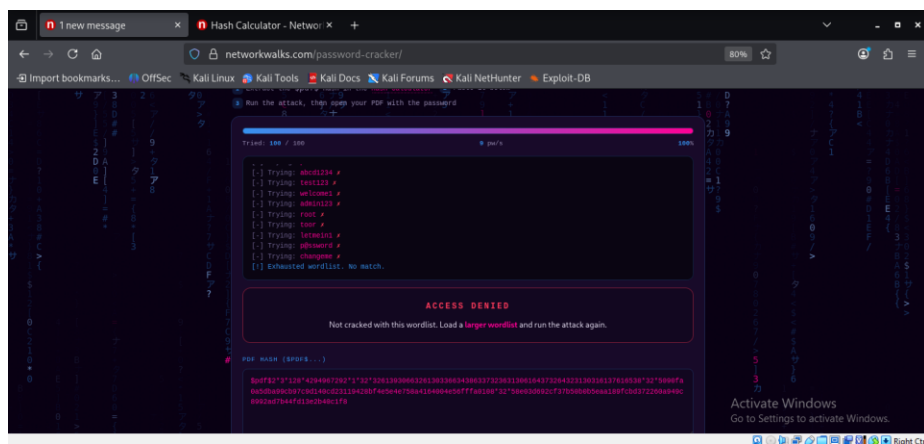


Figure F5.6 — Report 3 did not crack with the small list — no match found.

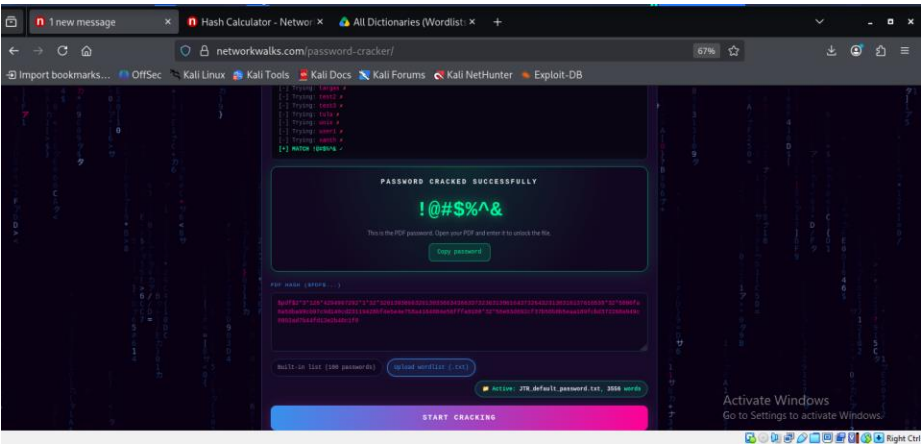


Figure F5.7 — Report 3 cracked with a bigger word list: '!@#\$\$%^&'.

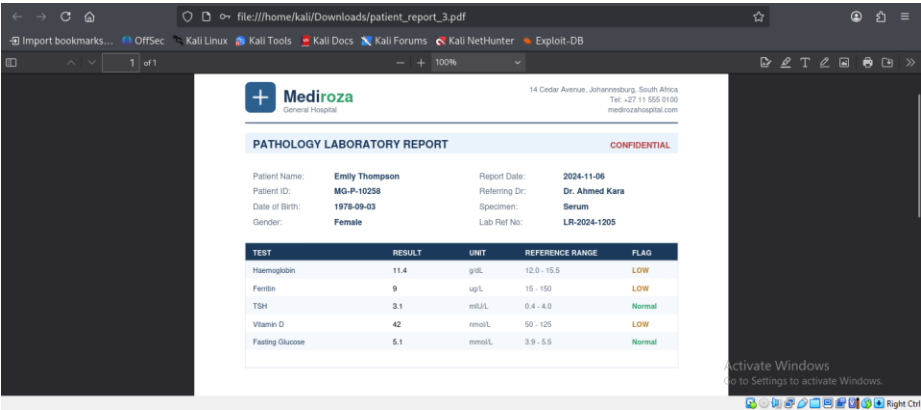


Figure F5.8 — Report 3 opened: patient Emily Thompson's lab results.

M3 — Critical Data Exposure

Goal: dig deeper into what we found, to see what else was exposed on the server.

F6 — PDF File Details Leak the Backup's Location [MEDIUM]

Where	Hidden file details inside the decrypted Report 3 PDF
What we found	- Every file carries hidden details called metadata — things like the author's name, the software used, and any notes left behind. - We checked Report 3's metadata with a tool called exiftool. - It contained a note from a staff member: 'DB backup moved to /old before site migration, do not delete'. - It also showed the staff username (j.malik) and the exact software version running the site (Mediroza CMS 1.4.2).
Why it matters	That one leftover note is what led us straight to the hospital's full database backup — turning a small, overlooked detail into the single biggest finding of this whole test.

```
(kali@kali)-[~]
$ exiftool "/home/kali/Downloads/report3_open.pdf"
ExifTool Version Number      : 13.55
File Name                    : report3_open.pdf
Directory                    : /home/kali/Downloads
File Size                    : 2.9 kB
File Modification Date/Time  : 2026:10:02 04:36:28-04:00
File Access Date/Time       : 2026:10:02 04:36:28-04:00
File Inode Change Date/Time  : 2026:10:02 04:36:28-04:00
File Permissions             : -rw-rw-r--
File Type                    : PDF
File Type Extension         : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : j.malik
Comments                     : DB backup moved to /old before site migration, do not delete
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                      : Full Blood Count
Title                        : Pathology Report - E. Thompson
Page Count                   : 1
```

Figure F6.1 — Hidden file details revealing the backup's location, a staff username, and the CMS version.

F4 — Old Backup Folder Is Open for Anyone to Browse [HIGH]

Where	https://medirozahospital.com/old/
What we found	- Following the note from F6, we opened the /old/ folder directly in a browser. - Instead of blocking us, the server showed a full file listing — every file in that folder, visible to anyone.
Why it matters	This setting is called 'directory listing' and it should always be switched off. It is what let us actually see and download the backup file in the next finding, without needing to guess its name.

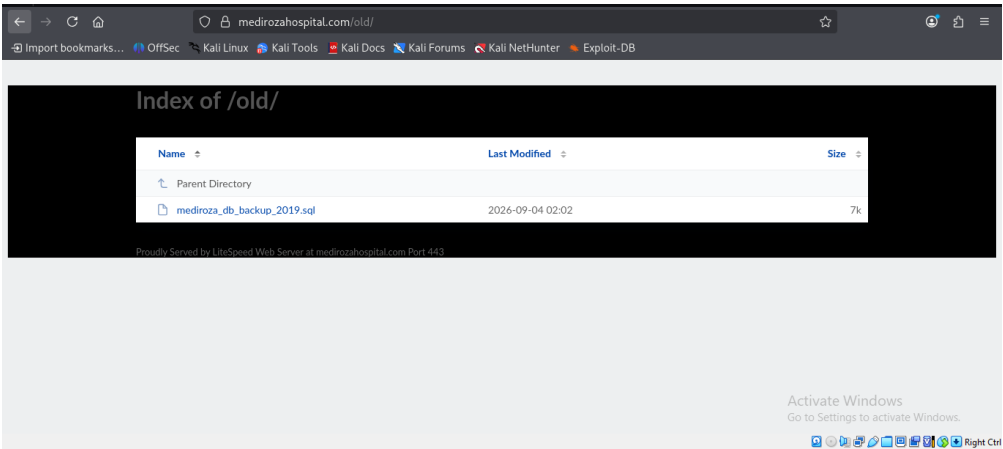


Figure F4.1 — The /old/ folder listing its one file, open to anyone.

F3 — Full Database Backup File Is Public — No Login Needed [CRITICAL]

Where	https://medirozahospital.com/old/mediroza_db_backup_2019.sql
What we found	- We downloaded the backup file directly — no username, no password, nothing stopped us. - It is a full database export, containing two full tables: 'staff' (30 people) and 'shareholders' (10 people). - The staff table lists each person's full name, job title, department, phone number, national ID number, monthly salary, and the date they joined. - The shareholder table lists each owner's name, their share percentage, how many shares they hold, and their share type.

Why it matters	This is the single worst finding of the test. National ID numbers can be used for identity theft. Salaries are meant to stay private. Shareholder details are commercially sensitive. All of it was sitting in a public file, open to anyone on the internet, with zero protection.
----------------	---

```
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary` zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85011023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassin','Senior Registrar','Emergency & Trauma','y.cassin@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Misha Singh','Physiotherapist','Rehabilitation','m.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
```

Figure F3.1 — Raw backup file showing staff names, ID numbers and salaries.

```
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Figure F3.2 — Raw backup file showing shareholder names and ownership percentages.

The full, readable version of both tables is on the next pages.

Staff Data — Full Table (30 Employees)

This is the complete staff list recovered from the exposed database backup file (F3). It includes every employee's salary and national ID number.

ID	Full Name	Job Title	Department	Phone	National ID	Salary (ZAR/mo)	Joined
1	Dr. Rajesh Naidoo	Chief Pathologist	Lab	+27 82 101 2007	85021013011081	138,000	2009-03-16
2	Sarah Botha	Chief Financial Officer	Finance	+27 82 102 2014	85031023022082	152,000	2011-07-01
3	Dr. Johan van der Merwe	Medical Director	Management	+27 82 103 2021	85041033033083	160,000	2007-01-22
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	+27 82 104 2028	85051043044084	132,000	2012-09-10
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	+27 82 105 2035	85061053055085	128,000	2013-02-18
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	+27 82 106 2042	85071063066086	74,000	2018-05-04
7	Michael Roberts	HR Director	Human Resources	+27 82 107 2049	85081073077087	96,000	2011-10-15
8	Susan Pretorius	HR Officer	Human Resources	+27 82 108 2056	85091083088088	32,000	2016-08-23
9	Jameel Malik	IT Systems Administrator	IT	+27 82 109 2063	85101093099089	58,000	2015-08-08
10	Thabo Molefe	Network Engineer	IT	+27 82 110 2070	85111103110090	46,000	2017-10-02
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	+27 82 111 2077	85121113112091	34,000	2016-01-19
12	Lerato Mokoena	Registered Nurse	Pediatrics	+27 82 112 2084	85011123132093	33,000	2016-06-07
13	Bongani Ndlovu	Registered Nurse	Cardiology	+27 82 113 2091	85021133134094	35,000	2015-12-01
14	Zanele Mahlangu	Nursing Sister	Theatre	+27 82 114 2098	85121143154095	42,000	2013-03-25
15	Kagiso Sithole	Pharmacist	Pharmacy	+27 82 115 2105	85041153165086	61,000	2014-09-08
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	+27 82 116 2112	85051163176087	26,000	2019-02-14
17	Themba Nkosi	Radiographer	Radiology	+27 82 117 2119	85061173187088	44,000	2016-07-30
18	Palesa Radebe	Radiographer	Radiology	+27 82 118 2126	85071183198089	43,000	2017-04-11
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	+27 82 119 2133	85081193209081	41,000	2015-05-20
20	Kavitha Govender	Lab Technician	Diagnostics Lab	+27 82 120 2140	85091203220082	35,000	2018-08-06
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	+27 82 121 2147	85101213231083	130,000	2012-02-12
22	Dr. Fatima Patel	Pediatrician	Pediatrics	+27 82 122 2154	85111223242084	135,000	2013-10-17
23	Dr. Nisha Singh	Physiotherapist	Rehabilitation	+27 82 123 2161	85121233253085	48,000	2016-11-09
24	Dr. Vikram Chetty	Anaesthetist	Theatre	+27 82 124 2168	85011243264086	135,000	2011-06-13
25	David Smith	Facilities Manager	Operations	+27 82 125 2175	85021253275087	52,000	2014-01-27
26	Karen O'Connor	Billing Administrator	Finance	+27 82 126 2182	85031263286088	29,000	2018-03-19
27	James Wilson	Security Supervisor	Operations	+27 82 127 2189	85041273297089	27,000	2019-09-02
28	Linda Fourie	Receptionist	Front Office	+27 82 128 2196	85051283308081	19,000	2020-02-10
29	Peter van Wyk	Procurement Officer	Supply Chain	+27 82 129 2203	85061293319082	38,000	2015-08-24
30	Andile Mbeki	Ward Clerk	Administration	+27 82 130 2210	85071303330083	21,000	2019-11-05

Shareholder Data — Full Table (10 Shareholders)

This is the complete shareholder list recovered from the same backup file (F3). It shows who owns the hospital and in what proportion.

ID	Shareholder Name	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Preferential
7	Dr. Ahmed Kara	8.0%	80,000	Ordinary
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

04. Risk Rating

Each problem is rated Critical, High, Medium or Low. The rating is based on two simple things: how easy it was to exploit (we had no password, no inside help), and how bad the damage would be if a real attacker found it.

M#	ID	Finding	Risk	Why this rating
M1	F8	robots.txt reveals hidden folders	Low	Just helped us find other issues faster — no data exposed by itself.
M1	F7	Login form leaks valid usernames	Low	Helps other attacks, but no actual data is exposed.
M1	F1	SQL injection on the login form	Critical	No password needed, and it can expose or damage the whole database.
M1	F2	Login can be bypassed to view patient reports	Critical	Real patient names and private medical files, exposed with no login.
M2	F5	Patient PDF passwords are weak and crackable	Medium	Needed an extra cracking step, but the passwords gave in almost instantly.
M3	F6	PDF file details leak the backup's location	Medium	Indirect, but it is exactly what led us to the biggest finding (F3).
M3	F4	Old backup folder is open for anyone to browse	High	Easy to fix, but it is the direct reason F3 could be downloaded.
M3	F3	Full database backup file is public — no login needed	Critical	Salaries, national ID numbers and ownership data, all fully exposed.

05. Recommendations — How to Fix This

M1 — F1: SQL Injection

- Never paste user input straight into a database command. Use 'parameterised queries' — a safe, standard way of building database commands that developers already know how to do.
- Turn off detailed error messages on the live site. Show the visitor a plain, generic error, and save the detailed one only in a private server log.
- A Web Application Firewall (WAF) can help catch attacks like this, but it should back up a real code fix, not replace it.

M1 — F2: Login Bypass

- Check on the server, every single time, that the person asking for a report is actually logged in and it is really their own report.
- Fixing F1 (the SQL injection) will close this hole too, since both problems come from the same broken login check.

M1 — F7 & F8: Small Information Leaks

- Make the login form say the same generic message every time: 'Invalid username or password' — never confirm which part was wrong.
- Lock an account, or slow down repeated tries, after several wrong attempts in a row.
- Remove /staff/ and /old/ from robots.txt, and properly protect those folders with real logins instead of just hiding the names.

M2 — F5: Weak Passwords

- Use strong, random, computer-generated passwords for every patient file — never simple ones like '123456' or 'password'.
- Better yet, let patients view their reports after logging in on the website, instead of handing out a downloadable file that can be cracked offline.

M3 — F6: Metadata Leak

- Before sending any PDF to a patient, strip out internal notes, staff usernames, and software version details from the file.
- Check the system that creates these PDFs (Mediroza CMS 1.4.2) for other places where internal notes might leak into patient files.

M3 — F4 & F3: Exposed Backup File

- Delete mediroza_db_backup_2019.sql (and check for any other old backups) from anywhere the website can serve it. Store backups outside the public web folder, always.
- Turn off folder listing on the web server, everywhere, so no folder can ever be browsed like this again.
- Treat this as a real data breach. Work out if staff and shareholders need to be formally told, under data protection law.
- Change any passwords or keys found inside that backup file, and check server logs for anyone else who may have downloaded it before.

What to Fix First

In this order:

- 1. Delete the exposed backup file and turn off folder listing — this data is live and exposed right now.
- 2. Fix the SQL injection and login bypass in the patient login page.
- 3. Fix the weak PDF passwords and strip the metadata leak.
- 4. Clean up the smaller issues (username leak, robots.txt) in the next update.

This project was done in a safe, controlled environment for learning purposes, with written permission from the client. Never use these methods on a real system without written permission.